

TLP:CLEAR

Анализ угроз на основе ханипотов

Ежемесячный отчёт — апрель 2026

SSH Brute-force | WannaCry/EternalBlue | LLM Abuse | ICS/OT | SIP Scanning

Параметр	Значение
Период отчёта	1-30 апреля 2026
Дата анализа	7 мая 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ-ВЫСОКИЙ
Узлы ханипотов	DE (Hetzner), US (HOSTKEY), RU (SelectEI), PL (новый — ICS/OT)
SSH-события	578 657 попыток входа на всех узлах
Образцы малвари	654 уникальных (992 просканировано, 100% malicious)
Abuse-отчёты	184 сформировано, 35 отправлено провайдерам

1. Краткое заключение

В апреле 2026 года распределённая сеть ханипотов — включающая узлы в Германии (DE), США (US) и России (RU), а также новый ICS/OT-узел, запущенный в Польше (PL) 28 апреля, — зафиксировала устойчивую и разнообразную атакующую активность по всем отслеживаемым сервисам. Суммарно зафиксировано 578 657 попыток входа по SSH, собрано 654 уникальных образца вредоносного ПО (все подтверждены как malicious), а также более 236 000 событий SIP/VoIP-сканирования. Полученные данные отражают активный ландшафт угроз с широким спектром целей атакующих: перехват учётных данных, криптомайнинг, расширение ботнетов и всё более активное злоупотребление AI-инфраструктурой.

Ряд находок требует повышенного внимания. PE32-файлы, соответствующие сигнатурам WannaCry, продолжают распространяться в большом масштабе — 884 образца сработали по правилу YARA WannaCry_Ransomware, — что подтверждает актуальность угрозы устаревших механизмов распространения программ-вымогателей даже в 2026 году. Скоординированная SSH-кампания целенаправленно перебирала имена пользователей Solana-валидаторов (sol, solana, solv), набрав свыше 37 000 попыток на всех узлах. Отдельно зафиксировано 54 032 несанкционированных inference-запроса к ханипоту Ollama API, а в событиях Docker API выявлено 1 049 сессий с классификацией llm-abuse — свидетельство растущего интереса злоумышленников к захвату открытых AI-сервисов в целях кражи вычислительных ресурсов.

Атрибуция инфраструктуры атакующих демонстрирует значительную зависимость от коммерческих облачных провайдеров. Наибольшее число атрибутированных обращений приходится на DigitalOcean (1 835 хитов), затем следуют OVH и Amazon AWS.

Примечательно, что 21 атрибутированное событие связано с Aeza International — хостером, включённым в санкционные списки ЕС и США, — и 8 событий с Proton66 OOO, известным bulletproof-хостером. Анализ TLS-трафика выявил 3 383 сессии с SNI api[.]telegram[.]org, что согласуется с использованием Telegram Bot API вредоносными семействами в качестве канала управления (C2). Наблюдались образцы Go-червя, соответствующие сигнатуре Panchan, использующего Discord в качестве вторичного C2-канала. Новый польский ICS/OT-ханипот, эмулирующий Modbus, IEC 61850, DNP3 и S7, начал привлекать трафик в течение первых часов после запуска; полный статистический анализ будет включён в майский отчёт.

2. Описание инфраструктуры

Сеть ханипотов состоит из четырёх узлов, размещённых в географически и юридически разных хостинговых средах. Каждый узел работает со стандартизированным набором эмулируемых сервисов. Узел US зеркалирует весь трафик датацентра HOSTKEY, поэтому его абсолютные показатели соединений включают транзитный и соседский трафик наряду с прямыми атаками на ханипот; для анализа атак используются отфильтрованные датасеты.

Узел	Провайдер / Регион	Отслеживаемые протоколы	Статус
DE	Hetzner, Фалькенштайн, Германия	SSH (Cowrie), HTTP/HTTPS, SMB (:445), Ollama API (:11434), Docker API, WinBox, Kubelet, SIP/VoIP	Активен — весь месяц
US	HOSTKEY, Нью-Йорк, США	SSH (Cowrie), HTTP/HTTPS, SIP/VoIP, Docker API (зеркало всего ДЦ)	Активен — весь месяц; транзит отфильтрован для статистики атак
RU	SelectEl, Москва, Россия	SSH (Cowrie), SIP/VoIP, HTTP/HTTPS	Активен — весь месяц
PL	Новый узел, Польша	Modbus, IEC 61850, DNP3, S7 (эмуляция ICS/OT)	Запущен 28 апреля — данные только за 3 дня

3. Объём атак и тренды

Объём попыток входа по SSH на каждом узле в апреле 2026 года. Наибольший абсолютный объём неуспешных попыток — на узле DE. Суммарно на всех узлах 30 984 попытки зафиксированы как «успешные» в слое эмуляции ханипота, что обеспечило видимость постэксплуатационных команд и загружаемых полезных нагрузок.

Узел	Успешных входов	Неуспешных попыток	Итого
DE	14 886	237 636	252 522
US	13 232	139 888	153 120
RU	2 866	170 149	173 015
ИТОГО	30 984	547 673	578 657

Объём событий по типам сервисов за апрель 2026:

Сервис / Ханипот	Событий / Сессий	Примечание
SSH (Cowrie)	578 657 попыток входа	35 активных кампаний; 1 921 уникальный IP атакующих
Ollama API	54 032 события	Несанкционированные LLM inference-запросы

SIP/VoIP	236 573 события	DE: 46 316 RU: 79 342 US: 110 915
Docker API	7 834 события	Разбивка по категориям — в разделе 4.3
WinBox (MikroTik)	7 442 события	Сканирование управляющего интерфейса MikroTik
Kubelet (Kubernetes)	1 494 события	Зондирование API-сервера Kubernetes

4. Ключевые находки

4.1 WannaCry/EternalBlue: продолжение распространения через SMB

Наиболее распространённым YARA-совпадением среди собранных образцов вредоносного ПО стало правило WannaCry_Ransomware, сработавшее на 884 PE32-образцах — единственный наибольший гомогенный кластер обнаружений за месяц. Коррелирующее правило SUSP_Imphash_Mar23_2 совпало с теми же 884 образцами, что соответствует хорошо задокументированному imphash-отпечатку, общему для вариантов WannaCry. Все образцы собраны преимущественно через ханипот dionaea на порту 445 (SMB): узел DE получил 80 500 входящих соединений на этот порт за месяц. Продолжение распространения производных WannaCry спустя почти десятилетие после вспышки 2017 года отражает две устойчивые реальности: большой пул незащищённых Windows-систем с открытым доступом в интернет, уязвимых к EternalBlue (CVE-2017-0144 / MS17-010), и постоянное повторное использование утёкшего инструментария АНБ в массовом вредоносном ПО. Хотя полезная нагрузка шифровальщика во многих образцах может быть нефункциональна из-за sinkhole-домена killswitch, базовый механизм распространения червя полностью работоспособен.

4.2 Целевая кампания брутфорса против Solana-валидаторов

Статистически значимый кластер SSH-попыток нацелен на имена пользователей, связанные с инфраструктурой Solana-валидаторов. По всем узлам ханипота имена sol (18 399 попыток), solana (11 509 попыток) и solv (7 063 попытки) суммарно составили 37 021 попытку входа — позиции 4, 6 и 7 соответственно в глобальном топ-15 имён, сразу после root (226 565), admin (28 348) и ubuntu (24 957).

Концентрация и специфичность этих имён свидетельствует о целенаправленной кампании против Solana-валидаторов, а не об оппортунистическом credential stuffing. Solana-валидаторы являются экономически привлекательными целями: скомпрометированный валидатор позволяет извлечь ключи стейкинга, перенаправить вознаграждения, нарушить участие в консенсусе или использовать его как плацдарм для атаки на связанную инфраструктуру горячих кошельков. Присутствие имени solv — связанного с продуктом стейкинга Solv Protocol — указывает на то, что злоумышленники отслеживают экосистемный инструментарий и соответствующим образом обновляют словари.

4.3 Злоупотребление открытой LLM-инфраструктурой (Ollama + Docker API)

Два сервиса ханипота зафиксировали значительное злоупотребление AI/LLM-инфраструктурой. Ханипот Ollama API (эмулирующий неаутентифицированный endpoint Ollama inference на порту 11434) зарегистрировал 54 032 события за апрель, представляющих несанкционированные попытки использовать сервис для генерации текста — фактически хищение вычислительных ресурсов для запуска языковых моделей за чужой счёт. Порт 11434 узла DE получил 95 146 событий на уровне Zeek-соединений, подтверждая устойчивый интерес к этой поверхности атаки.

Ханипот Docker API зарегистрировал 7 834 события суммарно. Из них 1 049 сессий классифицированы в категорию llm-abuse — попытки развернуть LLM inference-контейнеры через открытые Docker API. Разбивка событий Docker API за апрель 2026:

Категория сессии	Кол-во	Описание
recon	1 338	Перечисление API и обнаружение возможностей
llm-abuse	1 049	Попытки развернуть или использовать LLM inference-контейнеры
unknown	507	Неклассифицированные сессии
docker-worm	481	Автоматическое распространение червя через Docker API
mikrotik-recon	38	Обнаружение MikroTik RouterOS через Docker API
malware-dropper	30	Доставка вредоносных нагрузок через запуск контейнеров
cryptominer	2	Развёртывание контейнеров для криптомайнинга

4.4 Telegram Bot API как C2-канал вредоносного ПО

Анализ SSL-логов Zeek выявил 3 383 TLS-сессии с SNI api[.]telegram[.]org на узлах DE и RU. Этот трафик не инициирован операторами ханипота — никаких Telegram-инструментов на инфраструктуре ханипота не развёрнуто, — поэтому он атрибутируется вредоносному ПО, выполняемому в среде ханипота и использующему Telegram Bot API в качестве канала управления.

Использование Telegram как C2-транспорта хорошо задокументировано для многих семейств вредоносного ПО. Telegram Bot API привлекателен для авторов малвари по нескольким причинам: трафик зашифрован (TLS к инфраструктуре Telegram), не требует собственной C2-инфраструктуры у злоумышленника, сложно заблокировать без воздействия на легитимный Telegram-трафик, а токены ботов обеспечивают дешёвый одноразовый механизм аутентификации. Объём 3 383 сессии за месяц свидетельствует о множестве различных образцов или устойчивой активности от повторных заражений.

4.5 SSH-червь Panchan/Go с C2 через Discord

Семь ELF-образцов сработали по правилу Discord_C2_ELF YARA, шесть образцов соответствовали сигнатуре Panchan_SSHWorm_Go. Все семь образцов Discord_C2_ELF также сработали по SUSP_ELF_LNX_UPX_Compressed_File, указывая на UPX-упаковку, характерную для известной методологии упаковки Panchan. Panchan — SSH-червь на Go с P2P-архитектурой, впервые задокументированный в 2022 году; распространяется через перебор учётных данных и кражу SSH-ключей, после чего формирует mesh-сеть C2, дополненную Discord Webhook-коммуникациями.

MIPS и ARM ELF-образцы в апрельской коллекции (14 ARM, 4 MIPS из всех ELF-образцов) соответствуют кросс-архитектурному таргетингу Panchan — IoT-устройства и встроенные Linux-системы наряду со стандартными x86-64-серверами. Discord Webhook обеспечивает злоумышленникам канал оповещения о новых компрометациях в реальном времени без какой-либо выделенной инфраструктуры.

4.6 Массовое SIP/VoIP-сканирование

SIP/VoIP-сканирование стало одним из наиболее объёмных наблюдений месяца: 236 573 события суммарно по трём основным узлам — DE (46 316 Zeek SIP-событий), RU (79 342 события, включая 34 863 записи Zeek SIP-лога) и US (110 915 событий). Порт 5060 узла RU получил 65 815 событий на уровне соединений, порт DE — 46 316 событий, подтверждая SIP как основную цель сканирования.

SIP-сканирование, как правило, ведётся с двумя целями: обнаружение открытой VoIP-инфраструктуры для toll fraud (несанкционированные звонки через захваченные SIP-аккаунты или PBX-системы) и снятие отпечатков VoIP-endpoint'ов для последующей эксплуатации. Масштаб наблюдаемого сканирования — более 230 000 событий за один месяц — отражает высокоавтоматизированные интернет-широкие SIP-кампании.

4.7 Инфраструктура атакующих: санкционированный и bulletproof-хостинг

Корреляционный анализ ASN-атрибуции выявил атрибутированный трафик от двух примечательных хостинг-провайдеров. Aeza International — 21 коррелирующий хит: провайдер включён в санкционные списки Европейского союза и США за предоставление инфраструктуры для киберпреступной деятельности. Proton66 ООО — 8 хитов: российская AS, широко задокументированная как bulletproof-хостер, используемый операторами ransomware, брокерами первоначального доступа и другими киберпреступными группировками.

Доминирующим провайдером инфраструктуры атакующих по объёму остаётся DigitalOcean (1 835 коррелирующих хитов), далее следуют OVH (436) и Amazon AWS (430). Концентрация трафика атакующих у крупных коммерческих облачных провайдеров отражает операционное предпочтение к использованию дешёвой и быстро заменяемой VPS-инфраструктуры.

5. Анализ вредоносного программного обеспечения

Суммарно за апрель 2026 года проиндексировано 654 уникальных образца, собранных из трёх источников: di0naea (578 образцов, преимущественно PE32 через SMB/HTTP), cowrie (57 образцов, загруженных злоумышленниками в SSH-сессиях) и URL-харвестер, отслеживающий dropper-URL (19 образцов). Все 992 образца, поданные на автоматическое сканирование, получили вердикт malicious. По узлам: DE — 298 образцов, US — 228, RU — 128.

Распределение по типам файлов:

Тип файла	Кол-во	Доля
PE32/DLL (Windows)	930	93,8%
ELF (Linux)	51	5,1%
Shell-скрипты	7	0,7%
Другое	4	0,4%

Linux ELF-образцы по архитектуре процессора:

Архитектура	Образцов
x86-64	25
ARM	14
MIPS	4
i386	3
ARC	1

Топ YARA-срабатываний за апрель 2026:

Правило YARA	Срабатываний	Интерпретация
WannaCry_Ransomware	884	PE32 семейства WannaCry; распространение через SMB/EternalBlue
SUSP_Imphash_Mar23_2	884	Коррелирующий imphash-отпечаток — тот же кластер образцов
Go_SSHWorm_Generic	7	Обобщённое обнаружение Go SSH-червей
Discord_C2_ELF	7	ELF с C2 через Discord Webhook
SUSP_ELF_LNX_UPX_Compressed_File	7	UPX-упакованные ELF — упаковка для уклонения
Panchan_SSHWorm_Go	6	P2P Go SSH-червь Panchan

SUSP_XORed_Mozilla_Oct19	3	XOR-обфусцированные строки (паттерн Mozilla/Firefox)
MAL_ARM_LNX_Mirai_Mar13_2022	2	Ботнет Mirai — ARM Linux-вариант
MAL_ELF_Xlogin_Nov24_1	1	ELF-вор учётных данных Xlogin

C2-индикаторы, извлечённые из образцов вредоносного ПО:

Индикатор	Тип	Связанное ПО / Назначение
xmrig[.]com	Домен (дефанг)	XMRIg криптомайнер — дистрибуция клиента
nicehash[.]com	Домен (дефанг)	Майнинг-пул NiceHash — выплаты злоумышленника
api[.]telegram[.]org	Домен (дефанг)	Telegram Bot API — C2-канал вредоносного ПО
discord[.]com / discordapp[.]com	Домен (дефанг)	Discord Webhook — C2 Panchan/Discord_C2_ELF
api[.]ipify[.]org	Домен (дефанг)	Публичный IP-lookup — анти-геофенсинг
Mirai XOR-ключи: 0x22355627, 0x544f4e49	XOR-ключи	Обфускация C2-доменов Mirai — декодируется в runtime

6. Атрибуция источников атак

Атрибуция стран-источников основана на обработанных корреляционным анализатором данных. США и Китай суммарно обеспечивают наибольший объём атрибутированных событий — это объясняется концентрацией облачной VPS-инфраструктуры в этих странах, а не прямой государственной спонсированностью атак.

#	Страна	Атрибутированных событий
1	США (US)	6 092
2	Китай (CN)	5 973
3	Румыния (RO)	2 857
4	Германия (DE)	2 398
5	Нидерланды (NL)	2 222
6	Россия (RU)	1 903
7	Вьетнам (VN)	1 449
8	Индия (IN)	774

9	Болгария (BG)	743
10	Гонконг (HK)	679
11	Южная Корея (KR)	629
12	Франция (FR)	568
13	Тайвань (TW)	523
14	Индонезия (ID)	505
15	Сингапур (SG)	503

Инфраструктура атакующих по автономным системам (ASN-корреляция):

Провайдер / ASN	Хитов	Примечание
DigitalOcean (AS14061)	1 835	Наибольший единственный источник инфраструктуры атакующих
OVH (AS16276)	436	Европейский облачный/VPS-провайдер
Amazon AWS (AS16509)	430	Коммерческое облако — легко provisioned VPS
GCS (Global Connectivity)	248	
Alibaba Cloud (AS45102)	184	APAC облачный провайдер
VPSVAULT.HOST LTD	180	Бюджетный VPS-хостер
M247 Europe (AS9009)	91	Европейский транзит/хостинг
Aeza International (AS210644)	21	САНКЦИОНИРОВАН — санкционные списки ЕС/США
Proton66 OOO (AS198953)	8	Bulletproof-хостинг — известная криминальная инфраструктура

7. Конвейер Abuse Reporting

Автоматизированный конвейер abuse-отчётности сформировал 184 инцидент-отчёта за апрель 2026 года, охватив 184 уникальных вредоносных IP-адреса у 135 провайдеров и 108 уникальных abuse-контактов. Из них 35 отчётов (19%) отправлены напрямую в abuse-службы провайдеров; оставшиеся 149 находятся в очереди ожидания, соблюдая лимиты частоты обращений.

Провайдер	ASN	Отчётов сформировано
Microsoft Corporation	AS8075	8
Google LLC	AS396982	5

Korea Telecom	AS4766	5
UCLOUD HK	AS135377	5
DigitalOcean	AS14061	4
Censys Inc	AS398324	3
Tencent Cloud	AS45090	3

8. ICS/OT Ханипот — Первые наблюдения (узел PL)

28 апреля 2026 года запущен ICS/OT-ханипот в Польше. Узел эмулирует протоколы промышленных систем управления, характерные для энергетического сектора и критической инфраструктуры. Географическое размещение в Польше обосновано повышенной угрозой для промышленной инфраструктуры Восточной Европы и задокументированным интересом государственно-аффилированных акторов к таргетингу ICS/OT по всему восточному флангу НАТО.

Протокол	Стандарт	Типичное применение
Modbus TCP	IEC 61158	SCADA, ПЛК, промышленные датчики
IEC 61850	IEC 61850	Автоматизация подстанций, энергетика
DNP3	IEEE 1815	Энергетика, водоснабжение, нефтегаз (США/Канада)
S7comm	Siemens S7	Программируемые контроллеры Siemens SIMATIC

Имея лишь три дня данных (28–30 апреля), статистический анализ преждевременен. Первичные наблюдения подтверждают, что узел получает сетевой трафик на отслеживаемые ICS-порты, что соответствует задокументированному интернет-широкому сканированию ICS-протоколов (502/Modbus, 102/S7, 20000/DNP3 и связанные порты IEC 61850). Полный анализ будет включён в ежемесячный отчёт за май 2026.

9. Сводная таблица индикаторов компрометации (IOC)

Все доменные и URL-индикаторы дефангированы согласно требованиям обработки TLP:CLEAR. Перед использованием в инструментах безопасности замените [.] на . и hxxps на https.

Тип	Значение	Контекст / Описание
Домен (C2)	api[.]telegram[.]org	Telegram Bot API — C2 вредоносного ПО; 3 383 TLS-сессии
Домен (C2)	discord[.]com	Discord Webhook C2 — образцы Panchan/Discord_C2_ELF

TLP: CLEAR

Домен (C2)	discordapp[.]com	Discord API endpoint — тот же C2-кластер
Домен (майнер)	xmrig[.]com	XMRIg криптомайнер — endpoint дистрибуции
Домен (пул)	nicehash[.]com	Майнинг-пул NiceHash — выплатный endpoint злоумышленника
Домен (разведка)	api[.]jipify[.]org	Публичный IP-lookup — техника анти-геофенсинг
Сеть (ASN)	Aeza International (AS210644)	Санкционированный хостер; 21 атрибутированный хит
Сеть (ASN)	Proton66 OOO (AS198953)	Bulletproof-хостер; 8 атрибутированных хитов
YARA	WannaCry_Ransomware	884 совпадения PE32-образцов — распространение через SMB/EternalBlue
YARA	Panchan_SSHWorm_Go	6 образцов — Go SSH-червь с Discord C2
YARA	Discord_C2_ELF	7 ELF-образцов — Discord Webhook exfil/C2
YARA	MAL_ARM_LNX_Mirai_Mar13_2022	2 ARM ELF-образца — вариант ботнета Mirai
XOR-ключ	0x22355627	Ключ XOR-обфускации C2-доменов Mirai
XOR-ключ	0x544f4e49	Ключ XOR-обфускации C2-доменов Mirai
TLS SNI	api[.]telegram[.]org	3 383 сессии — C2 вредоносного ПО (узлы DE + RU)
Порт	tcp/445	SMB — 80 500 соединений (DE); вектор распространения WannaCry
Порт	tcp/11434	Ollama API — 54 032 несанкционированных inference-события
Порт	udp+tcp/5060	SIP/VoIP — 236 573 события по всем узлам
Имя пользователя	sol / solana / solv	Цели SSH-брутфорса валидаторов Solana — 37 021 попытка

HASSH	af8223ac9914f509afdadf5f7ee94e	Топ SSH-отпечаток клиента — 28 005 сессий
HASSH	16443846184eafde36765c9bab2f4397	Второй SSH-отпечаток — 24 171 сессия
HASSH	01ca35584ad5a1b66cf6a9846b5b2821	Третий SSH-отпечаток — 21 527 сессий

10. Мappings MITRE ATT&CK

Наблюдаемые действия атакующих в соответствии с фреймворком MITRE ATT&CK (матрицы Enterprise и ICS).

ID техники	Название	Наблюдаемые свидетельства
T1110	Brute Force	578 657 SSH-попыток входа; целевые учётные данные Solana-валидаторов (sol/solana/solv: 37 021 попытка)
T1595	Active Scanning	236 573 SIP/VoIP-события; 80 500 SMB/:445 соединений; 7 442 WinBox; 1 494 Kubelet-зонда
T1595.002	Vulnerability Scanning	Эксплуатация EternalBlue/MS17-010 через SMB; зондирование Ollama API (порт 11434)
T1059	Command and Scripting Interpreter	7 shell-скриптов в коллекции вредоносного ПО, загруженных через SSH/Cowrie-сессии
T1496	Resource Hijacking	54 032 несанкционированных inference-события Ollama API; Docker API llm-abuse (1 049 сессий); образцы криптомайнера (xmrig[.]com, nicehash[.]com)
T1071.001	Application Layer Protocol: Web Protocols	C2 вредоносного ПО через HTTPS к api[.]telegram[.]org (3 383 TLS-сессии)
T1102	Web Service	Telegram Bot API как C2 (3 383 сессии); Discord Webhook C2 (Panchan, Discord_C2_ELF — 7 образцов)
T1583.003	Acquire Infrastructure: Virtual Private Server	Инфраструктура атакующих преимущественно на VPS: DigitalOcean (1 835 хитов), OVH (436), AWS (430)
T1584	Compromise Infrastructure	Aeza International (санкционирован, 21 хит) и Proton66 ООО (bulletproof, 8 хитов) как источники атак

TLP:CLEAR

T1027	Obfuscated Files or Information	UPX-упакованные ELF (7 хитов); XOR-обфускация доменов Mirai (ключи 0x22355627, 0x544f4e49)
T1078	Valid Accounts	30 984 успешных входов в ханипот; кража SSH-ключей червём Panchan для горизонтального перемещения
T1021.004	Remote Services: SSH	Распространение SSH-червя Panchan; SSH-брутфорс по всем трём основным узлам; 1 921 уникальный IP атакующих
T1498	Network Denial of Service	Мониторинг DDoSia/NoName057: 18 C2-узлов (14 онлайн), 153 активных цели
T0840	Network Connection Enumeration (ICS)	Сканирование ICS/OT-протоколов на узле PL (Modbus/502, S7/102, DNP3/20000, IEC 61850) — первичные наблюдения

TLP:CLEAR — Этот документ может распространяться без ограничений.